

IV.A Resilience

Action Summary

Management should evaluate whether there are appropriate resources to ensure resilience, including an accessible, off-site repository of software, configuration settings, and related documentation, appropriate backups of data, and off-site infrastructure to operate recovery systems.

Furthermore, management should discuss potential disaster scenarios with the entity's third-party service providers to prepare for an event. Subsequently, management should assess the entity's immediate or short-term space requirements, systems, and personnel capacity to assume or transfer failed operations. Additionally, management should assess critical third-party service providers' susceptibility to simultaneous attacks and verify their resilience capabilities.

Examiners should review the following:

- Appropriateness of resilience practices, including the adequacy of recovery infrastructure and backup processes.
- Integration with disaster recovery services to protect against data destruction.
- Assessment of alternate data communications infrastructure between the entity and critical third-party service providers.
- Evaluation of the entity's susceptibility to multiple threat scenarios in resilience planning, testing, and recovery strategies.
- Designation of emergency personnel, including for critical business process-level employees.

Resilience is “the ability to prepare for and adapt to changing conditions and withstand and recover rapidly from disruptions. Resilience includes the ability to withstand and recover from deliberate attacks, accidents, or naturally occurring threats or incidents.”²¹ The business strategy, not technology solutions, should drive resilience. Resilience extends beyond recovery capabilities to incorporate proactive measures for mitigating the risk of a disruptive event in the overall design of operations and processes. Resilience strategies, including maintaining security standards, should extend across the entire business, including outsourced activities. Management should evaluate whether the entity has appropriate resources (e.g., human, financial, time) for resilience. When developing the entity's resilience strategies, management should consider lessons learned from previous events.

²¹ Refer to the Presidential Policy Directive/PPD-21, [Presidential Policy Directive -- Critical Infrastructure Security and Resilience](#) February 12, 2013.

IV.A.1 Physical

Physical resilience is the traditional approach to business continuity and includes IT architecture, infrastructure, facilities, and communications. To avoid the potential for failures after a disruption, management, when possible, should diversify telecommunication lines, establish redundant connections between branches and data centers, create backups, identify multiple power sources, and verify geographic diversity of key entity locations.

IV.A.2 Cyber Resilience

A challenge for cyber resilience is maintaining operations despite ever-changing risks (e.g., malware, data or system destruction and corruption, and communications infrastructure disruption). The sophistication and frequency of cyber attacks increase the potential for disruption and destruction of data and systems. Given the broad and increasing spectrum of cyber threats, resilience measures should be flexible enough to adapt to a diverse range of events. For example, a cyber attack could impact both production and backup facilities simultaneously, potentially rendering both inoperable, whether hosted internally or by a third-party service provider.

In addition, adversaries may initiate a secondary disruption (e.g., the original disruption could be the impact of a hurricane with the secondary disruption being false transactions or accessing sensitive data). Alternatively, adversaries can launch simultaneous attacks (e.g., a distributed denial of service (DDoS) attack combined with a wire transfer compromise). Therefore, management should adhere to established security and privacy policies and processes to comply with applicable regulations, even during disruptive events.

IV.A.3 Data Backup and Replication

Management should maintain data confidentiality, integrity, and availability for all iterations of data, including data backup and replication, not just focused on the production environment. Data backup and re-creation are important to recovering critical business functions in the event of disruptions. Backup files are commonly created electronically and can be mirrored at an off-site location, backed up on removable media, stored temporarily on network servers until rotated off-site, or backed up to a cloud environment. Backups should be readily accessible and adhere to the entity's information security policy.

Management should reassess backup and recovery strategies as the technology and threat environments evolve. For real-time or high-volume systems, it may be appropriate to have advanced duplication and backup methods. These advanced methods, including cloud and mirroring, provide high availability and are detailed in section V.E.1, "Data Center Recovery Alternatives."

Management should maintain an accessible, off-site repository of software, configuration settings, and related documentation. Even standard software configurations can vary from one location to another. Differences could include parameter settings and modifications, security profiles, reporting options, account information, customized software changes, or other options.

Failure to back up software configurations could result in inoperability or could delay recovery. Therefore, a comprehensive backup of critical software is important. Software backups generally consist of the following components:

- Operating systems.
- Applications.
- Utility programs.
- Databases.
- Other critical software identified in the BIA.

Management should establish effective procedures to recover critical networks and systems. Procedures may address the following:

- Backup types (physical or virtual).
- Backup levels (full, incremental, or differential).
- Updates and retention cycle frequencies.
- Software and hardware compatibility reviews.
- Data transmission controls.
- Data repository maintenance.

Refer to the *IT Handbook's* "Operations" booklet for additional information.

Data replication (also referred to as data synchronization or mirroring) is the process of copying data, usually with the objective of maintaining identical data sets in separate locations. Replication is important in any environment for resilience. Furthermore, management should consider integrity controls during replication so that data changes in production, development, and quality assurance environments are applied throughout the network.

Two common data replication processes used for information systems are synchronous and asynchronous. Synchronous replication represents the direct application of the data by applying changes at the same time. In practice, synchronous replication allows data to be transmitted in a continuous stream and minimizes data loss; however, it requires significant communication bandwidth and has limitations on the distance data can be transported due to latency issues. Synchronous replication is typically used for critical business functions where little or no data loss can be tolerated. Conversely, asynchronous replication is the indirect application of data through applying changes to a log before transit. In practice, asynchronous replication allows data to be transmitted in intermittent batches. While asynchronous replication increases the potential for data loss related to the fractions of a second required to transmit the data, this process requires less communication bandwidth and is useful for data transport over longer distances, due to reduced latency issues.

Management should determine the appropriate retention periods for each iteration of data backup. Entities should safeguard against replicating malware and data corruption. This risk is heightened with the use of near real-time data replication systems, as malware can be replicated undetected. Even with diagnostic tools, management could be unaware of an event that causes data integrity issues until well after it happens, as data could appear uncorrupted but later

determined to be inaccurate. Management may determine that the backup of critical data files should be subject to longer retention periods to ensure the ability to recover a backup prior to a corruption event.

Even in situations when the primary and backup facilities are inoperable or corrupted, customers of the entities expect to be able to access their accounts. Entities should develop appropriate cyber resilience processes (e.g., recovery of data and business operations, rebuilding network capabilities and restoring data) that enable restoration of critical services if the institution or its critical service providers fall victim to a destructive cyber attack or similar event. BCM should include the ability to protect offline data backups from destructive malware or other threats that may corrupt production and online backup versions of data. An example of an industry initiative to assist in addressing the resilience of customer account information is Sheltered Harbor.²²

IV.A.4 Personnel

Resilience is dependent upon personnel availability to maintain critical business processes. Personnel could be unavailable or distracted during such events as natural disasters, severe weather events, or pandemics.²³ While any one employee's role may not be designated as mission critical, management should plan for mass absenteeism during an event or disruption. Previous catastrophic events (e.g., Hurricane Katrina²⁴) demonstrate that personnel availability affects timely recovery.

Management should plan for events during which personnel may not be able to access facilities and critical personnel may not be available immediately after the disruption. Public infrastructure and transportation systems may not be operating, and telecommunication systems may be overburdened and unavailable. Therefore, management should consider:

- Staffing and skills needed to operate critical functions related to business continuity.
- Lodging arrangements for displaced employees and their families.
- Basic necessities and services for displaced employees, including water, food, clothing, childcare, transportation, and cash.
- On-site medical support and mobile command centers.
- Secure telecommunication options if employees work from an alternate location.
- Designated emergency personnel, including critical business process-level employees.

²² Sheltered Harbor is a voluntary industry initiative launched in 2015 following a series of cybersecurity simulation exercises between public and private sectors, known as the Hamilton Series. The purpose of the proposed Sheltered Harbor standard is to promote the stability and resiliency of the financial sector and to preserve public confidence in the financial system. The Sheltered Harbor standard proposes a combination of secure data vaulting of critical customer account information with a comprehensive resilience plan to provide customers timely access to their account information and underlying funds during a prolonged systems outage or destructive cyber attack. ([Sheltered Harbor](#)).

²³ Refer to the FFIEC's [FFIEC Highlights Pandemic Preparedness Guidance](#).

²⁴ Refer to the FFIEC's [Lessons Learned From Hurricane Katrina: Preparing Your Institution for a Catastrophic Event](#).

IV.A.5 Third-Party Service Providers

Many entities depend on third-party service providers to perform or support critical operations. A disruption in the delivery of those services can have a direct impact on entities' resilience. A critical failure at a widely used third-party service provider could have large-scale consequences. Management should assess critical third-party service providers' susceptibility to multiple event scenarios and verify such third parties' resilience capabilities. An entity's third-party service provider can be a single point of failure if management has not considered alternative providers or other contingency plans. If an alternative third-party service provider is not readily available, management should consider options to continue business operations and reevaluate resilience options periodically as conditions may change. Resilience planning should be closely coordinated with third-party service providers.

Establishing well-defined expectations with third-party service providers is important to business resilience. Contracts and SLAs with third-party service providers should detail roles and responsibilities of each party to promote resilience. Ongoing monitoring of the entity's third-party service providers helps management identify potential weaknesses in the third-party service provider's resilience that could affect the entity's operations.

Management's review of an entity's third-party service provider's BCM program may include independent audit reports or SOC reports. SOC reports can contain valuable information about the third-party service provider's products and processes. If management relies on SOC reports, it should verify whether business continuity activities are audited, including whether the scope and depth of review are sufficient to allow management to evaluate the third-party service provider's control environment.²⁵ Depending on the scope of the audit testing, additional inquiry and activities may be appropriate to understand the resilience of the third-party service provider.

Management should consider the same risks outlined in their entity's own internal BCP(s) in relation to third-party service providers, as well as:

- Capacity of third-party service provider to meet client recovery objectives in the agreements, relative to other clients' needs.
- Ability to participate in recovery testing with third-party service providers and access to testing results.
- Ability to move outsourced processes either in-house or to another third-party service provider.
- Alternative resource options (e.g., personnel and systems) for when primary services cannot be delivered.
- Data confidentiality, integrity, and availability (e.g., transportability and interoperability).

²⁵ SOC 1 reports cover controls at the third-party service provider that affect financial reporting. Business continuity activities are usually reported in unaudited sections of SOC 1 reports because they often do not have a direct correlation to the preparation of the financial statements, unless an event happened during the audit period. SOC 2 reports cover trust services criteria and include activities such as security, confidentiality, availability, privacy, and integrity. Audit firms typically do not opine on the quality of the business continuity activities, because it is difficult to predict what would happen during an actual event. Activities related to business continuity such as replication, plan development, and testing may be included in SOC 2 reports covering availability.

- Financial capacity to continue meeting contractual obligations.
- Services concentrated in a limited number of third-party service providers.

Business continuity-related provisions found in contracts and SLAs may include the following:

- Time parameter(s) for contracted service(s).
- Appropriate baseline metrics describing management's resilience and recovery expectations (e.g., an incident response metric to ensure timely response to events impacting business continuity and resilience).
- Periodic service reviews to ensure up-to-date agreements with all parties involved.

If operations at a third-party service provider cease, the length of time required to convert to an alternate system would, for most applications, exceed a reasonable RTO. To the extent possible, management should establish plans for the resilience of third-party service providers supporting critical operations.

IV.A.6 Telecommunications

Given the critical nature of telecommunications, management should ensure appropriate redundancy levels in the entity's telecommunications infrastructure. The entity's telecommunications infrastructure may contain single points of failure that are outside the control of a single entity. Management should understand the limitations of the entity's third-party telecommunications providers' infrastructure. For example, multiple carriers may rely on the same telecommunications backbone. Key aspects management should consider in establishing telecommunication redundancy include:

- Identifying and mitigating single points of failure across the entity's infrastructure.
- Developing and maintaining a plan to address an outage in the telecommunications lines with the entity's primary third-party service providers.
- Establishing redundant telecommunications links with each of the entity's third-party service providers through a contractual arrangement, which allows either party to switch its connection to an alternate communication path.
- Reviewing the entity's third-party service providers' plans and determining whether critical services can be restored within acceptable time frames.
- Developing guidelines, commensurate with the entity's size, complexity, and risk profile, to diversify connections to mitigate the risk of a telecommunications failure.
- Assessing the communications technology that bridges the transmission distance between the telecommunications service provider and the entity, sometimes referred to as the "last mile," for single points of failure.
- Monitoring relationships with telecommunications providers to manage risks.
- Inquiring about the physical paths used by telecommunications providers and verifying that system redundancies have been properly implemented.

Communication is critical to the financial services sector and other industries. Therefore, management should consider the following services provided by the federal government. These services give participants priority access to telecommunications during a wide-spread event.

- The Telecommunications Service Priority (TSP)²⁶ program.
- Government Emergency Telecommunications Service (GETS).²⁷
- Wireless Priority Service (WPS),²⁸ which is the wireless complement to GETS.

IV.A.7 Power

The financial industry is dependent on power to run its technology infrastructure and to supply basic necessities to personnel and customers. A long-term power outage can negatively impact an entity's resilience. Management should implement measures to provide electricity in the event of a short-term power disruption. Furthermore, management should develop plans to provide electricity in the event of a long-term power disruption. As part of its short-term and long-term plans, management should consider the following:

- Alternate energy sources (e.g., generators, multiple power grids).
- Fuel requirements, both for fuel on-hand and contracts with suppliers for deliveries during events, and any potential impediments to obtaining fuel.
- Load capacity of generators (e.g., length of time, useful life, level of power supplied).
- Continued maintenance of generators.
- Testing of generators.

IV.A.8 Change Management

Management should implement and align a consistent change management process throughout the entity, making sure to include BCM. As changes are made to production systems and business processes during the normal course of business, recovery systems and documentation at alternate locations should similarly be updated to reflect production and primary system changes.

The change management process should allow for expedient implementation of emergency changes during an event, such as changing an access control list to provide rapid access for

²⁶ Refer to the DHS's "[Telecommunications Service Priority](#)" (TSP) webpage. The TSP program provides service vendors a Federal Communications Commission mandate to prioritize requests by identifying those services critical to national security and emergency preparedness. TSP-designated circuits are recovered first in an emergency. Management may contact the entity's primary federal regulator for information on the TSP program and whether the entity qualifies for a TSP designation. If the entity qualifies, management should integrate the TSP program into the entity's BCP.

²⁷ Refer to the DHS's "[Government Emergency Telecommunications Service](#)" (GETS) webpage. GETS provides "priority access and prioritized processing in the local and long distance segments of the landline networks, greatly increasing the probability of call completion." It is intended to be used in an emergency or crisis situation when the landline network is congested and the probability of completing a normal call is reduced. Management may request GETS cards by submitting an application to the entity's primary federal regulator.

²⁸ Refer to the DHS's "[Wireless Priority Service](#)" webpage.

troubleshooting and analysis. Change tickets and corresponding activity should be reviewed for appropriateness once the event has been resolved. Even during events, changes should still be properly authorized, monitored, and documented. Poorly administered emergency changes can result in further disruption. Additionally, the interrelated nature of systems can compound disruptions to previously unaffected systems. After an emergency event, systems documentation should be updated for any changes made. Change management elements are addressed in more detail in the *IT Handbook's* “Development and Acquisition” and “Operations” booklets.

IV.B Communications

Management should consider, plan for, and prepare multiple mechanisms to communicate with others. For example, when traditional voice communications and telecommunications are impaired or inoperable, management may consider alternative communications systems such as text messaging through employer-provided and personal mobile phones, personal email, and instant messaging. Other common solutions include an inbound hotline number, an informational webpage, or a two-way polling phone system. Regardless of the communication device used, appropriate controls to safeguard customer and other sensitive information should be maintained.

BCM should include communication protocols and contact lists to notify stakeholders. Management should consider the content and process for developing such protocols and templates. Communication protocols should incorporate strategic communications and crisis management approaches in concert with public affairs or external communications (e.g., prepared public/press statements, media response plans, managing social media, etc.). Communication protocols provide customers, third-party service providers, and other external groups a means to communicate when normal channels are inoperable. External groups could include the following:

- Regulatory agencies (federal and states).
- Emergency responders.
- Law enforcement.
- Financial sector trade associations.
- Customers, third-party service providers, and other third parties (e.g., counterparties, clearing and settlement partners, payment system operators).
- Information-sharing entities (e.g., FS-ISAC).

V Business Continuity Plan

Action Summary

Management should develop business continuity plan(s) (BCP) with sufficient detail in relation to the entity's size and complexity. The BCP should address key business needs and incorporate inputs from all business units.

Examiners should review the plan for the following:

- Authorities, responsibilities, and relocation strategies.
- Communications protocols, event management, business continuity, and disaster recovery.
- Liquidity concerns before and during an adverse event.²⁹
- Alternatives for payment systems, facilities and infrastructure, data center(s), and branch relocation during a disaster.

As shown in figure 2, a BCP is an important component of BCM. The BCP documents the practices and procedures for continuing business operations during a disruption. The BCP focuses on critical business functions and varies according to the entity's size and complexity. The BCP includes specific elements, such as incident response, disaster recovery, and crisis management. Smaller entities may have a single BCP that includes these elements whereas large, complex entities may have multiple plans supported by subsidiary components for business functions, locations, or departments. Furthermore, the BCP should be a living document, regularly updated so that it remains current with system enhancements and organizational changes.³⁰

A comprehensive plan describes the authorities, responsibilities, procedures, and relocation strategies. Components of the plan should include:

- Roles, responsibilities, and required skills for entity personnel and third-party service providers.
- Solutions to various types of foreseeable disruptions, including those emanating from cyber threats.
- Escalation thresholds.
- Immediate steps to protect personnel and customers and minimize damage.
- Prioritization and procedures to recover functions, services, and processes.
- Critical information protection (e.g., physical, electronic, hybrid, and use of off-site storage).

²⁹ Refer to NIST SP 800-61, [Computer Security Incident Handling Guide](#).

³⁰ Refer to "BCP Strategy Concept," NIST SP 800-34 Rev. 1, [Contingency Planning Guide for Federal Information Systems](#). NOTE: While this document pertains to federal information systems, the principles are relevant for non-federal information systems.

- Logistical arrangements (e.g., housing, transportation, or food) for personnel at the recovery locations.
- Network equipment, connectivity, and communication needs, including entity-owned and personal mobile devices.
- Personnel at alternate sites, including arrangements for those permanently located at the alternate facility.
- Scope and frequency of testing.
- Resumption of a normalized state for business processes.

Representatives from all business units should contribute to BCP development and implementation. The BCP may be developed and maintained internally or outsourced. In either case, the entity's board and senior management should be responsible for the BCP. Management should verify the third-party service provider's qualifications and expertise when outsourcing BCP development. Management should work with the third-party service provider to design executable and viable strategies. Regardless of its development process, the BCP and supporting documentation should be stored so that it is readily accessible by personnel during adverse events.

V.A Event Management

The BCP may define various situations as events, disruptions, or triggers. An event is an occurrence or change in circumstances that may affect operations. An event can be physical, cyber, or a combination of both. A disruption is either an anticipated or unplanned event that causes operations to degrade or fail for an unacceptable length of time (e.g., a minor or extended power outage, an extended unavailable network, or equipment or facility damage or destruction). A trigger is an event that prompts management's response. Predefined threshold escalation triggers are a key element of a BCP, and responses should be designed to mitigate the impact from adverse events.

The BCP should include event management procedures that detail reasonably foreseeable event types and provide thresholds and responses. Procedures should describe how to report an event to management and the situations that warrant notification to those who address events. Management should consider establishing a team(s)³¹ to address events. Individuals managing the event may change depending on the nature of the event and team member availability. While the team should manage the event and communicate with stakeholders, event monitoring is an entity-wide responsibility (e.g., board, senior management, and other personnel).

Responses may include activities, programs, or systems that protect life and property, meet basic human needs, and preserve the entity's operational capability. Examples of event responses include:

- Switching operations to a backup facility after a software upgrade and subsequent rollback fail.

³¹ Depending on the entity's size and complexity, authority to respond to an event may fall to an individual, a team, or multiple teams. The term "team" is used for purposes of this booklet.